

Unit 2

Intrusion and Database Security Firewalls

An intrusion is an unwelcome or unauthorized entry into a place, situation or someone's personal space.

Intrusion refers to **unauthorized access to a computer system, network or data.**

Example: The Company installed an intrusion detection system (IDS) to prevent hacking.

Intrusion is the act of entering or interfering **without permission.**

In cybersecurity, an intrusion is unauthorized access to a digital system, network, or data, typically by a malicious actor seeking to steal information, disrupt operations or cause damage. It involves attackers using various techniques like malware, phishing or exploiting vulnerabilities to bypass security and gain entry, often monitored by **Intrusion Detection Systems (IDS)** that alert admins, and **Intrusion Prevention Systems (IPS)** that actively block threats, protecting the **CIA** (Confidentiality, Integrity, Availability) triad of security.

Examples by context:

- **Daily life:**

Someone reading your private messages is an intrusion of privacy.

- **Security:**

Breaking into a house is an intrusion.

- **Cybersecurity:**

A hacker accessing a computer system without permission is an intrusion.

Types of Intrusions

- **Malware-based**: Introducing malicious code (viruses, Trojans, ransomware) via phishing, infected files etc., to steal data or create backdoors.
- **Network Intrusions**
Unauthorized access to an entire network, often involving port scans, DoS/DDoS attacks, or Man-in-the-Middle (MitM) attacks
- **System Intrusions**: Targeting specific computers, using password cracking or software flaws to gain control.
- **Social Engineering**: Tricking users (e.g., via phishing) into revealing sensitive info or granting access.

Intrusion Detection Message Exchange Format (IDMEF)

The Intrusion Detection Message Exchange Format (**IDMEF**) is a standardized **XML-based data format** (defined in **RFC-Request for Comments 4765**) for **sharing security alerts** and event data between different intrusion detection/prevention systems (**IDS/IPS**), security management tools and collection systems, allowing automated processing and interoperability for cyber incident response.

RFC primarily stands for Request for Comments, a series of formal documents defining the technical standards, protocols and processes for the internet, published by the **Internet Engineering Task Force** (IETF).

It provides a common language to describe attacks, victims and response actions, enabling systems to communicate effectively with related protocols like IDXP (Intrusion Detection Exchange Protocol) defined for transport.

Intrusion Detection and Prevention Systems

Intrusion Detection System (IDS)

Intrusion Detection System (IDS) observes network traffic for malicious transactions and sends immediate alerts when it is observed. It is software that checks a network or system for malicious activities or policy violations. Intrusion detection systems (IDS) are incredibly powerful systems for **monitoring traffic and detecting threats on a network or system.**

Intrusion Detection in cybersecurity is the process of monitoring computer systems, networks or applications to identify unauthorized access, malicious activities or security policy violations. In simple terms, it is a security mechanism that **detects attacks or suspicious behavior** and alerts administrators so they can respond quickly.

An **IDS** is a hardware or software tool that continuously analyzes traffic and system activities to detect intrusions.

Main Purpose

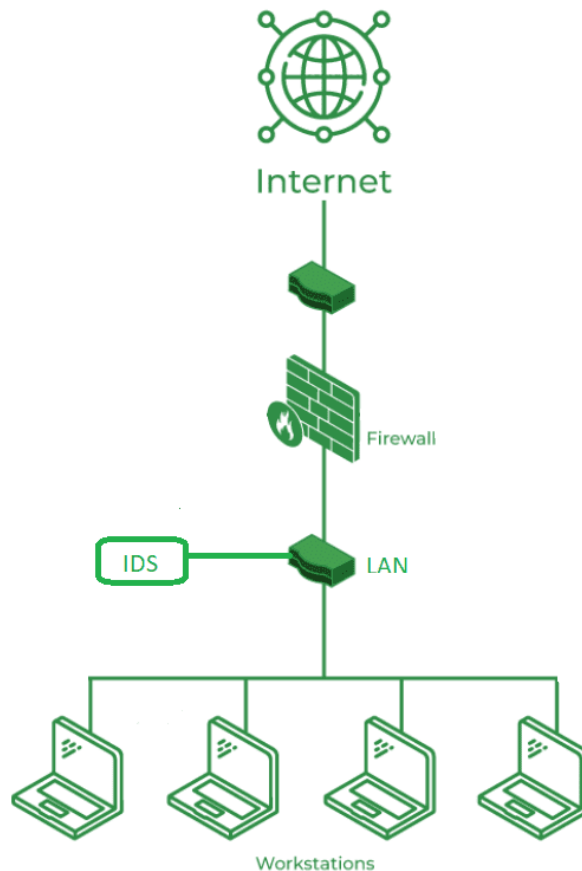
- Identify cyber attacks in real time
- Detect misuse, hacking attempts or malware
- Alert security teams before serious damage occurs

Working of Intrusion Detection System (IDS)

An IDS (Intrusion Detection System) monitors the traffic on a computer network to detect any suspicious activity. It analyzes the data flowing through the network to look for patterns and signs of abnormal behavior.

The IDS compares the network activity to a set of predefined rules and patterns to identify any activity that might indicate an attack or intrusion. If the IDS detect something that matches one of these rules or patterns, it sends an alert to the system administrator.

The system administrator can then investigate the alert and take action to prevent any damage or further intrusion.



Why Are Intrusion Detection Systems (IDS) Important?

An Intrusion Detection System (IDS) adds **extra protection to your cybersecurity setup**, making it very important. It works with your other security tools to catch threats that get past your main defenses. So, if your main system misses something, the IDS will alert you to the threat.

Types of Intrusion Detection Systems

1. Network-based IDS (NIDS)

- Monitors **network traffic**
- Placed at strategic points in a network
- Detects attacks like:
 - DoS/DDoS attacks
 - Port scanning
 - Man-in-the-middle attacks

2. Host-based IDS (HIDS)

- Monitors **individual systems (hosts)**
- Analyzes:
 - System logs
 - File integrity
 - User activities

Detection Techniques

1. Signature-Based Detection

- Compares activities with **known attack signatures**
- Effective for known threats

- Cannot detect new (zero-day) attacks

2. Anomaly-Based Detection

- Detects deviations from **normal behavior**
- Can identify unknown attacks
- May produce false positives

3. Hybrid Detection

- Combines both signature and anomaly-based methods
- More accurate and reliable

Examples of Intrusion Activities

- Unauthorized login attempts
- Malware infection
- SQL injection attacks
- Privilege escalation
- Data exfiltration

Advantages of IDS

- Early attack detection
- Improves network visibility
- Helps in forensic analysis

Limitations of IDS

- Does not stop attacks automatically
- Can generate false alarms
- Requires continuous monitoring

Benefits of IDS

Detects Malicious Activity: IDS can detect any suspicious activities and alert the system administrator before any significant damage is done.

Improves Network Performance: IDS can identify any performance issues on the network, which can be addressed to improve network performance.

Compliance Requirements: IDS can help in meeting compliance requirements by monitoring network activity and generating reports.

Provides Insights: IDS generates valuable insights into network traffic, which can be used to identify any weaknesses and improve network security.

Intrusion Prevention Systems (IPS)

An Intrusion Prevention System (IPS) is a proactive **network security tool** that monitors traffic for threats and **automatically blocks or prevents malicious activity** like malware, DoS attacks and exploits by dropping packets, resetting connections or reconfiguring firewalls, acting as an upgraded, active version of an Intrusion Detection System (IDS). IPS can be network-based (NIPS for entire networks) or host-based (HIPS for individual devices) and use signature or anomaly detection to enforce security policies and meet compliance.

An intrusion prevention system (IPS) monitors network traffic for potential threats and automatically blocks them by alerting the security team, terminating dangerous connections, removing malicious content or triggering other security devices.

IPS threat prevention methods

When an IPS detects a threat, it logs the event and reports it to the SOC, often through a Security Information and Event Management (SIEM) tool.

SOC stands for **Security Operations Center**.

A Security Operations Center (SOC) is a centralized team, facility or function responsible for monitoring, detecting, analyzing and responding to cybersecurity threats in an organization. A SOC works 24/7 to protect an organization's IT infrastructure from cyberattacks.

Key functions include:

Continuous Monitoring – Watches networks, servers, systems and applications.

Threat Detection – Identifies suspicious activities and security incidents.

Incident Response – Investigates contains and mitigates cyber incidents.

Log Analysis – Analyzes logs from firewalls, IDS/IPS, servers and applications.

Vulnerability Management – Identifies and helps fix security weaknesses.

Compliance Reporting – Supports standards like ISO 27001, GDPR, PCI-DSS.

GDPR (General Data Protection Regulation)

GDPR is a data protection law of the European Union (EU) that regulates how personal data of individuals is collected, processed, and stored.

PCI-DSS (Payment Card Industry Data Security Standard)

PCI-DSS is a security standard designed to protect cardholder data.

Tools used in SOC

SIEM (e.g., Splunk, IBM QRadar, ArcSight)

IDS/IPS (Intrusion Detection/Prevention Systems)

EDR/XDR (Endpoint Detection & Response)

Firewalls

Threat Intelligence Platforms

But the IPS doesn't stop there. It automatically takes action against the threat by using techniques such as:

Blocking malicious traffic

An IPS may end a user's session, block a specific IP address or even block all traffic to a target. Some IPSs can redirect traffic to a honeypot, a decoy asset that makes the hackers think they've succeeded when, really, the SOC is watching them.

Removing malicious content

An IPS may allow traffic to continue but scrub the dangerous parts, such as by dropping malicious packets from a stream or removing a malicious attachment from an email.

Triggering other security devices

An IPS may prompt other security devices to act, such as by updating firewall rules to block a threat or changing router settings to prevent hackers from reaching their targets.

Enforcing security policies

Some IPSs can prevent attackers and unauthorized users from doing anything that violates company security policies. For example, if a user tries to transfer sensitive information out of a database it's not supposed to leave, the IPS would block them.

Types of intrusion prevention systems

IPS solutions can be software applications installed on endpoints, dedicated hardware devices connected to the network or delivered as cloud services. Because IPSs must be able to block malicious activity in real time, they're always placed "inline" on the network, meaning traffic passes directly through the IPS before reaching its destination.

IPSs are categorized based on where they sit in a network and what kind of activity they monitor. Many organizations use multiple types of IPSs in their networks.

Network-based intrusion prevention systems (NIPS)

A network-based intrusion prevention system (NIPS) monitors inbound and outbound traffic to devices across the network, inspecting individual packets for suspicious activity. NIPS monitors are placed at strategic points in the network. They often sit immediately behind firewalls at the network perimeter so they can stop malicious traffic breaking through. NIPS's may also be placed inside the network to monitor traffic to and from key assets, like critical data centers or devices.

Host-based intrusion prevention systems (HIPS)

A host-based intrusion prevention system (HIPS) is installed on a specific endpoint, like a laptop or **server and monitors only traffic to and from that device**. HIPS are usually used in conjunction with NIPS to add extra security to vital assets. HIPS can also block malicious activity from a compromised network node, like ransomware spreading from an infected device.

Network behavior analysis (NBA)

Network behavior analysis (NBA) solutions monitor network traffic flows. NBAs may inspect packets like other IPSs but many NBAs focus on higher-level details of communication sessions, such as source and destination IP addresses, ports used and the number of packets transmitted.

NBAs use anomaly-based detection methods, flagging and blocking any flows that deviate from the norm, like a DDoS attack on traffic or a malware-infected device communicating with an unknown command and control server.

Wireless intrusion prevention systems (WIPS)

A wireless intrusion prevention system (WIPS) monitors wireless network protocols for suspicious activity, like unauthorized users and devices accessing the company's WIFI. **If a WIPS detects an unknown entity on a wireless network, it can terminate the connection.** A WIPS can also help detect misconfigured or unsecured devices on a wifi network and intercept man-in-the-middle attacks, where a hacker secretly spies on users' communications.

Firewall

A firewall can be defined as a special type of **network security device** or a software program that monitors and filters incoming and outgoing network traffic based on a defined set of security rules. It acts as a barrier between internal private networks and external sources (such as the public Internet).

The primary purpose of a firewall is to allow non-threatening traffic and prevent malicious or unwanted data traffic for protecting the computer from viruses and attacks. **A firewall is a cybersecurity tool that filters network traffic and helps users block malicious software from accessing the Internet in infected computers.**

Types of Firewall

Depending on their structure and functionality, there are **different types of firewalls**. The following is a list of some common types of firewalls:

1. Packet-filtering firewalls:- A packet filtering firewall is the most basic type of firewall. It acts like a management program that monitors network traffic and filters incoming packets based on configured security rules. These firewalls are designed to block network traffic IP protocols, an IP address, and a port number if a data packet does not match the established rule-set.

2. Circuit-level Gateways:- Simplified type of firewall that can be easily configured to allow or block traffic without consuming significant computing resources. These types of firewalls typically operate at the session-level of the OSI model by verifying TCP (Transmission Control Protocol) connections and sessions. Circuit-level gateways are designed to ensure that the established sessions are protected.

3. Application-level Gateways (Proxy Firewalls):- Proxy firewalls operate at the application layer as an intermediate device to filter incoming traffic between two end systems (e.g., network and traffic systems). That is why these firewalls are called 'Application-level Gateways'.

4. Stateful Multi-layer Inspection (SMLI) Firewalls:- Stateful multi-layer inspection firewalls include both packet inspection technology and TCP handshake verification, making SMLI firewalls superior to packet-filtering firewalls or circuit-level gateways. Additionally, these types of firewalls keep track of the status of established connections.

5. Next-generation Firewalls (NGFW):- Many of the latest released firewalls are usually defined as 'next-generation firewalls'. However, there is no specific definition for next-

5. Cybersecurity for all (CS4ALL) ERASMUS-EDU-2022-CBHE, No 101083009 generation firewalls. This type of firewall is usually defined as a security device combining the features and functionalities of other firewalls. These firewalls include

deep-packet inspection (DPI), surface-level packet inspection, and TCP handshake testing, etc.

6. Threat-focused NGFW:- Threat-focused NGFW includes all the features of a traditional NGFW. Additionally, they also provide advanced threat detection and remediation. These types of firewalls are capable of reacting against attacks quickly. With intelligent security automation, threat-focused NGFW set security rules and policies, further increasing the security of the overall defense system.

7. Network Address Translation (NAT) Firewalls:- Network address translation or NAT firewalls are primarily designed to access Internet traffic and block all unwanted connections. These types of firewalls usually hide the IP addresses of our devices, making it safe from attackers.

8. Cloud Firewalls:- Whenever a firewall is designed using a cloud solution, it is known as a cloud firewall or FaaS (firewall-as-a-service). Cloud firewalls are typically maintained and run on the Internet by third-party vendors. This type of firewall is considered similar to a proxy firewall. The reason for this is the use of cloud firewalls as proxy servers. However, they are configured based on requirements.

9. Unified Threat Management (UTM) Firewalls:-UTM firewalls are a special type of device that includes features of a stateful inspection firewall with anti-virus and intrusion prevention support. Such firewalls are designed to provide simplicity and ease of use. These firewalls can also add many other services, such as cloud management etc.

Importance of Firewalls

A firewall is the first line of defense in cybersecurity, acting as a security barrier between internal systems and external networks. It forces all traffic through a single checkpoint, where data packets are monitored, filtered and either allowed or blocked based on predefined rules. Firewalls are essential because they:

- **Prevent Unauthorized Access:** Like a locked door with a guard, only trusted users and traffic are allowed through.
 - **Block Malicious Traffic:** Harmful data such as viruses, phishing attempts, or denial-of-service (DoS) attacks are stopped before reaching the system.
 - **Protect Sensitive Information:** Safeguards personal and business data from theft or accidental leaks.
 - **Control Network Usage:** Enforces policies such as parental controls, workplace restrictions or government filtering.
-